

Software Risk Management

Risk Identification & Mitigation Strategies

CA Firm Attendance and Article Management System

Assignment No. 9

Group: E-17

Members: Nivesh Jain
Harsh Nayak
Rachit Ingole
Hasan Rupawalla

1. Problem Statement

Identify potential risks and prepare mitigation strategies for the **CA Firm Attendance and Article Management System** — a software development project. The exercise involves categorizing risks by type, assessing their probability and impact, constructing a risk matrix, and defining proactive mitigation and contingency plans for each identified risk.

2. Introduction

Risk management is a systematic process of identifying, analyzing, and responding to uncertainties that may adversely affect a software project's scope, schedule, cost, or quality. For the **CA Firm Attendance and Article Management System** — a web platform built on React.js, Node.js/Express, and MySQL that digitizes article trainee management through biometric face recognition, GPS-based geofencing, task assignment, and automated reporting — risk management is critical given the sensitive biometric data involved, real-time camera/GPS dependencies, and role-specific access requirements.

The risk management process for this project follows four steps:

- i) **Risk Identification** — Enumerate all potential risks across technical, project, and external dimensions.
- ii) **Risk Analysis** — Assess each risk's probability and impact on a 1–5 scale.
- iii) **Risk Prioritization** — Classify as High, Medium, or Low using a risk matrix.
- iv) **Risk Mitigation & Contingency** — Define proactive and reactive response strategies.

3. Risk Identification

3.1 Technical Risks

ID	Risk Description
TR-1	Face recognition fails due to low lighting, camera angle, or face occlusion
TR-2	GPS/Geolocation inaccuracy causes incorrect attendance denial (drift beyond 100m geofence)
TR-3	HTTPS requirement for camera/GPS not met, blocking attendance marking entirely
TR-4	MySQL database performance degradation under concurrent attendance/report queries
TR-5	JWT token compromise leading to unauthorized access
TR-6	Email notification delivery failure via Nodemailer (SMTP outage)
TR-7	Browser compatibility issues with face-api.js or Geolocation API

3.2 Project / Organizational Risks

ID	Risk Description
PR-1	Schedule slippage due to complexity of biometric integration
PR-2	Team unavailability during university examination periods
PR-3	Scope creep (e.g., adding AI performance analysis in Phase 1 instead of Phase 2)
PR-4	Unclear database schema changes causing backend-frontend rework
PR-5	Insufficient testing of attendance flow leading to production bugs

3.3 Business / External Risks

ID	Risk Description
BR-1	Biometric data (face descriptors) privacy/legal compliance risk (IT Act, PDPB India)
BR-2	Article trainee attempts to spoof attendance using a photo instead of live face
BR-3	SPCM sponsor changes requirements mid-project
BR-4	Low sponsor/stakeholder engagement leading to delayed UAT sign-off
BR-5	Firebase Cloud Messaging service disruption affecting push notifications

4. Risk Analysis

Risk Score (RS) = $P \times I$, where P = Probability (1–5) and I = Impact (1–5).

ID	Risk	P (1–5)	I (1–5)	RS	Level
TR-1	Face Recognition Failure	4	4	16	High
TR-2	GPS Inaccuracy / Drift	4	4	16	High
TR-3	HTTPS Not Configured	3	5	15	High
TR-4	Database Performance	3	4	12	Medium
TR-5	JWT Token Compromise	2	5	10	Medium
TR-6	Email Delivery Failure	2	3	6	Low
TR-7	Browser Compatibility	2	2	4	Low
PR-1	Schedule Slippage	4	4	16	High
PR-2	Team Unavailability	5	3	15	High
PR-3	Scope Creep	3	3	9	Medium
PR-4	DB Schema Instability	3	3	9	Medium
PR-5	Insufficient Testing	3	4	12	Medium
BR-1	Biometric Data Privacy	3	5	15	High
BR-2	Attendance Spoofing	4	4	16	High
BR-3	Sponsor Requirement Changes	3	4	12	Medium
BR-4	Delayed UAT Sign-off	3	3	9	Medium
BR-5	FCM Service Disruption	2	2	4	Low

5. Risk Matrix

RS = $P \times I$: **High** ≥ 15 , **Medium** 8–14, **Low** ≤ 7 .

	Low Impact (1–2)	Medium Impact (3)	High Impact (4)	Critical Impact (5)
Very High P (5)		PR-2		
High P (4)			TR-1, TR-2, PR-1, BR-2	
Medium P (3)		PR-3, PR-4, BR-4	TR-4, PR-5, BR-3	TR-3, BR-1
Low P (2)	TR-7	TR-6		TR-5
Very Low P (1)	BR-5			

Legend: ■ High Risk (RS ≥ 15) ■ Medium Risk (RS 8–14) ■ Low Risk (RS ≤ 7)

6. Risk Mitigation Strategies

6.1 High-Priority Risks (RS ≥ 15)

TR-1: Face Recognition Failure (RS = 16)

Probability: High (4) **Impact:** High (4)

Proactive Mitigation:

- Set a minimum Euclidean distance threshold of 0.6 (face-api.js) tuned during testing on diverse face samples.
- Provide a well-lit environment guidance message and re-capture prompt before denying attendance.
- Register multiple face samples per article trainee (front, slight left, slight right angles) during onboarding.
- Require a minimum camera resolution of 720p for face recognition to function.

Contingency Plan: If face recognition fails three consecutive times for a verified user, Admin can manually mark attendance with a supervisor override code. Log all override cases for audit purposes.

TR-2: GPS Inaccuracy / Drift (RS = 16)

Probability: High (4) **Impact:** High (4)

Proactive Mitigation:

- Make the geofencing radius configurable by Admin (default: 100m). This allows SPCM to adjust if the office building causes consistent GPS drift.
- Wait for GPS accuracy $< 50\text{m}$ before using the coordinate (reject coordinates with high uncertainty).

- Use the Browser Geolocation API's `enableHighAccuracy: true` option for better precision.

Contingency Plan: Admin can configure an expanded geofence radius (up to 300m) if consistent false denials are reported. Persistent GPS failures are logged and reviewable for manual approval.

TR-3: HTTPS Not Configured (RS = 15)

Probability: Medium (3) **Impact:** Critical (5)

Proactive Mitigation:

- Make HTTPS mandatory from day one of deployment (Render.com and Vercel both enforce HTTPS by default).
- During development, use `localhost` (which browsers treat as a secure context) for camera and GPS testing.
- Include HTTPS configuration in the deployment checklist; block production release without it.

Contingency Plan: If HTTPS cannot be configured on a custom domain immediately, use the platform's default HTTPS subdomain (e.g., `*.render.com`) as the production URL until the SSL certificate is issued.

PR-1: Schedule Slippage (RS = 16)

Probability: High (4) **Impact:** High (4)

Proactive Mitigation:

- Allocate 1.5 weeks' buffer at the deployment/documentation phase in the 14-week Gantt plan.
- Run T4 (Backend) and T6 (Frontend core) in parallel to compress the schedule.
- Lock feature scope at the SRS level; any new feature requires written approval from the project guide.

Contingency Plan: De-prioritize Phase 2 features (AI performance analysis, React Native mobile app). Deliver the core web system on time and document deferred features in the TBD list.

PR-2: Team Unavailability During Exams (RS = 15)

Probability: Very High (5) **Impact:** Medium (3)

Proactive Mitigation:

- Schedule low-effort tasks (documentation, DB schema, testing scripts) during examination weeks.
- Front-load high-complexity tasks (biometric integration, backend APIs) before exam season begins.
- Non-critical tasks T3, T6 carry 1–2 weeks of float specifically reserved for schedule flexibility.

Contingency Plan: Use the 1.5-week buffer in T10 (Deployment & Documentation) for post-exam catch-up. The team lead coordinates a 3-day intensive sprint after exams conclude.

BR-1: Biometric Data Privacy Risk (RS = 15)

Probability: Medium (3) **Impact:** Critical (5)

Proactive Mitigation:

- Store only face descriptor vectors (numerical arrays), never raw face images, in the database.
- Encrypt face descriptor data at rest using AES-256 encryption in MySQL.
- Display an explicit biometric data consent notice to each article trainee during onboarding.
- Provide a data deletion workflow: when an article account is deactivated, all biometric data is purged.

Contingency Plan: If a privacy complaint is raised, immediately suspend biometric attendance and revert to a manual check-in log while a legal/compliance review is conducted with SPCM.

BR-2: Attendance Spoofing via Photo (RS = 16)

Probability: High (4) **Impact:** High (4)

Proactive Mitigation:

- Use face-api.js's live detection capability (blinking/motion detection) to distinguish a live face from a static photo.
- Apply a confidence threshold of ≤ 0.6 Euclidean distance (tight matching) to reject lower-quality matches typical of printed photos.
- Combine dual-factor verification: face match **AND** GPS geofence — a photo presented from outside the office will still fail the GPS check.

Contingency Plan: Log all attendance attempts with the face confidence score and GPS coordinates. Admin can investigate anomalous patterns (e.g., very high confidence score from outside the office geofence).

6.2 Medium-Priority Risks (RS 8–14)

ID	Mitigation Strategy	Contingency Plan
TR-4	Add MySQL indexes on <code>article_id</code> , <code>date</code> in attendance/task tables. Use Sequelize query optimization. Limit report date ranges via the API.	Scale the MySQL instance vertically on the cloud host. Introduce server-side pagination for large queries.
TR-5	Use short-lived JWT tokens (1-hour access, 24-hour refresh). Store tokens in HttpOnly cookies. Implement token blacklist on logout.	Force all users offline, rotate the JWT secret, and issue new tokens.
PR-3	Enforce Change Control: any feature beyond the SRS requires project guide approval. Maintain a frozen scope document.	Move unapproved features to a Phase 2 backlog. Do not add to current sprint.
PR-4	Version-control the MySQL schema with migration scripts. Communicate schema changes in team chat before applying.	Run database migration rollback scripts. Revert to the last stable schema version.
PR-5	Write unit tests for all API endpoints before integration. Conduct a dedicated 2-week QA phase (T9) for the full attendance flow.	Extend the QA phase by pulling 2 days from the documentation buffer to address critical bugs.
BR-3	Conduct bi-weekly requirement review calls with SPCM to validate all features. Maintain a signed SRS as the formal contract.	Implement a formal Change Request (CR) process; any new sponsor requirement after SRS sign-off incurs a documented scope extension.
BR-4	Send the finished system demo to SPCM 1 week before final submission for early UAT feedback.	Schedule a structured UAT walkthrough session with SPCM in the last week of the project to get sign-off.

6.3 Low-Priority Risks (RS ≤ 7)

ID	Mitigation Strategy	Contingency Plan
TR-6	Configure Nodemailer with a reliable free SMTP service (Gmail App Password). Include retry logic for failed sends.	Log failed notifications in the database; display in-app notification as fallback if email delivery fails.
TR-7	Develop and test primarily on Google Chrome (required for camera/GPS). Use CSS autoprefixer for cross-browser styles.	Display a “please use Google Chrome” banner for users on unsupported browsers.
BR-5	Use Firebase Admin SDK with exponential backoff for push notification retries.	Fall back to in-app notifications (displayed on next login) and email as primary notification channels if FCM is down.

7. Risk Monitoring Plan

Activity	Description	Frequency
Weekly Risk Review	Team reviews risk register against project progress and Gantt milestones.	Weekly
Biometric Test Runs	Run face recognition and GPS attendance tests on real devices in the office environment.	Before each sprint release
Security Audit	Review JWT implementation, bcrypt rounds, and API endpoint authorization coverage.	Bi-weekly
Attendance Log Audit	Admin reviews automated flagging of anomalous attendance records (high confidence score despite GPS outside geofence).	Twice weekly
Sponsor Check-in	Meeting with SPCM representative to validate delivered features against requirements.	Bi-weekly
Risk Register Update	Update risk probability and status as project context evolves (e.g., reduce PR-2 probability after exam period ends).	Bi-weekly

8. Conclusion

This assignment identified 17 potential risks across technical, project, and business/external categories for the CA Firm Attendance and Article Management System. Risk analysis identified seven high-priority risks ($RS \geq 15$): face recognition failure (TR-1), GPS inaccuracy (TR-2), missing HTTPS configuration (TR-3), schedule slippage (PR-1), team unavailability (PR-2), biometric data privacy (BR-1), and attendance spoofing (BR-2).

The mitigation strategies leverage the system's own dual-factor verification architecture (face AND GPS) as a built-in anti-spoofing measure, while data privacy risks are mitigated through descriptor-only storage, encryption at rest, and explicit consent workflows. Project risks are addressed through Agile time-boxing, task parallelization, and a formally frozen SRS signed by SPCM.

The structured risk monitoring plan — featuring weekly team reviews, bi-weekly sponsor check-ins, and automated attendance log auditing — ensures risks are detected and responded to early, supporting on-time delivery of the system within the 14-week development window.